

Accuracy Report

Find Evil! — Autonomous DFIR Triage Agent

This report documents how accurately Find Evil! performs, verified against external ground truth — the NIST CFReDS answer key for the Hacking Case and the published Digital Corpora / Infosec write-ups for M57-Jean. Across both validated cases the agent reached the correct top-line conclusion and the correct decisive evidence, produced no fabricated artifacts, and labelled every finding by confidence.

Both cases were solved by the same single, generalist agent: it determines the investigation type from the evidence itself and adapts its analysis accordingly — no per-case configuration.

AT A GLANCE

Highlights

- Correct case classification on both cases (intrusion vs. exfiltration) — chosen autonomously from the evidence.
- Correct decisive evidence on both: Cain & Abel proven executed (prefetch) for Mr. Evil; m57biz.xls exfiltrated to the spoofed tuckgorge@gmail.com address for Jean.
- Zero fabricated or hallucinated artifacts in the validated runs — every reported item is genuinely on the disk.
- Every finding cited to an inode and labelled CONFIRMED / LIKELY / UNVERIFIED.
- Strong case isolation — distinct cases (distinct volume serials, distinct tracks) never share artifacts.
- Evidence integrity enforced architecturally — read-only access, SHA-256 verification, and a command deny-list the model cannot bypass.

METHODOLOGY

How We Assess Accuracy

Find Evil! is a triage tool: it surfaces the decisive findings of a case quickly and cites them. We assess it on three axes:

- Correctness — are the reported findings actually true of the evidence, verified against published ground truth?
- Precision — does it avoid asserting untrue things or naming things imprecisely?
- Recall — does it surface the artifacts a triage analyst should catch within scope?

Every finding is self-labelled CONFIRMED / LIKELY / UNVERIFIED — itself an accuracy mechanism. Anything short of certain is carried at LIKELY or UNVERIFIED, never asserted as CONFIRMED.

RESULTS

Per-Case Accuracy (Verified Against Ground Truth)

Case 1 — CFReDS “Mr. Evil” (intrusion)

Dimension	Result
Case classification	✓ Correct — attacker staging system (intrusion), chosen autonomously
Identity / system	✓ Correct — Greg Schardt / “Mr. Evil”, Windows XP, NTFS, offset 63
Cain & Abel executed	✓ Correct — prefetch CAIN.EXE-23D61279.pf is the canonical proof-of-execution; correctly the only tool marked CONFIRMED EXECUTED
Extended toolkit	✓ Correct, not hallucinated — pwdump / SAMDUMP / nmap / nbtscan / enum / netcat / NetBus / SECHOLE / GetAdmin / Brutus / John all genuinely on disk; correctly labelled PRESENT, not executed
Deleted wireless tools	✓ Correct — Ethereal / WinPcap / NetStumbler recovered from the Recycle Bin (INFO2), origin Mr. Evil\Desktop
Fabricated artifacts	✓ None — every tool reported is genuinely present on the disk
Filename inference	✓ Resolved — the current build labels ambiguous installers (e.g. lalsetup250.exe) UNVERIFIED rather than guessing a product name
Recall (scope)	⚠ By design — the deterministic collector targets offensive-tool names; deep registry / timeline attribution sub-questions are intentionally outside triage scope

Case 2 — M57-Jean (exfiltration)

Dimension	Result
Case classification	✓ Correct — social engineering / spear-phishing → data exfiltration (not intrusion/malware)
Exfiltrated data	✓ Correct — m57biz.xls (employee names, salaries, SSNs per ground truth)
Channel & recipient	✓ Correct — emailed to the external address tuckgorge@gmail.com
Spoof / pretext	✓ Correct — sender spoofed as alison@m57.biz; the real address is the Gmail account — the decisive artifact, correctly identified
Victim vs. perpetrator	✓ Correct — Jean is the victim; Alison’s identity was spoofed and she did not request the data
Event date	✓ Correct — 2008-07-20
Fabricated artifacts	✓ None
Confidence discipline	✓ Strong — spreadsheet contents and browser-cache relevance correctly carried as LIKELY / UNVERIFIED with a “not inspected” caveat

Bottom line: on both validated cases the agent reached the correct top-line conclusion and the correct decisive evidence, with zero fabricated artifacts. Anything short of certain was carried at LIKELY/ UNVERIFIED — never asserted as fact — and recall is bounded only by the deterministic collector’s scope.

ENGINEERING

Hardening Carried Out During Development

Find Evil! was hardened through deliberate, adversarial self-testing. Each class of error below was identified during development and eliminated — documenting them demonstrates the engineering rigour behind the validated results.

1. Case isolation. Prior-case data could once surface across runs; we added per-run bundle archiving and an explicit grounding rule, so every case is now hermetic. Verified across all runs — distinct serials, distinct tracks, no shared artifacts.
2. Whole-word indicator matching. Eliminated substring false positives (e.g. a page mentioning “McCain” no longer triggers a Cain & Abel hit).
3. Robust collection. Output directories are created before extraction, so artifacts are never silently missed by a collector step.
4. Present-vs-executed discipline. An explicit rule separates “present on disk” from “proven to have run.” This is why, on the validated Mr. Evil run, only Cain & Abel is **CONFIRMED EXECUTED**.
5. Accurate dashboards. A tolerant severity parser keeps the UI counts in lock-step with the report body.

INTEGRITY

Evidence Integrity

The most important guarantee for a forensic tool: the agent cannot modify the original evidence — and that guarantee is architectural, not a promise made to the model.

Enforced architecturally (the model cannot bypass)

- Read-only evidence — each image is `chmod 444` and opened read-only.
- SHA-256 baseline + verification — a hash is captured before analysis and re-checked afterward.
- Command deny-list — all write-class commands are denied (`dd`, `rm`, `mv`, `cp`, `mount`, `mkfs`, `tee`, `shred`, `truncate`, `chmod`, `chattr`).
- Read-only tool allow-list + `dontAsk` — only read-only Sleuth Kit operations (`mmls`, `fsstat`, `fls`, `icat`, `mactime`) are permitted.
- Sandboxed writes — all output is confined to a scratch directory; nothing the agent writes touches the evidence.

These are enforced by the operating system’s file permissions and the Claude Code permission engine — layers the model does not control.

SCOPE

Scope & Honest Limitations

- LLM variation is cosmetic — wording and finding order can vary between runs; the decisive conclusions have been stable across repeated runs.
- Recommended hardening — for a fully airtight submission, spot-check a handful of **CONFIRMED (PRESENT)** inodes with `icat` / `fls` to convert a keyword match into content-verified evidence; this is a natural use of the agent’s targeted-read capability.

Across both validated cases, Find Evil! delivered accurate, ground-truth-verified conclusions with full evidence traceability and architecturally-guaranteed evidence integrity.